OPERATION: SOCIAL ENGINEERING HEIST

BY HONDO, CHRISTIAN, ADAM, AND BLAKE

MISSION OBJECTIVE

- Inform people about social engineering
- Conduct a mock heist of project/network information at RowdyHacks
- Bring attention to the dangers of social engineering
- Demonstrate data leakage through complacency
- Conduct research on the potential vulnerability of students to SE

DESCRIPTION

Our team conducted a social engineering exercise at RowdyHacks to educate users on what Social Engineering (SE) is and to survey responses to establish a baseline for how vulnerable students could be to SE. We established two roles to conduct information and network reconnaissance and gather all available information.

Additionally, our exercise was a valid attempt to conduct a "heist" of information, showcasing the sheer amount of data one can get through lower effort.

We saw success at completing this objective.



WHY IT MATTERS?

Social Engineering is on the rise, and an increasing number and type of people are being targeted and exploited.

To counter social engineering, you must inform and educate the public about what social engineering is, the various forms that it comes in and the harm that it can cause.

We also wanted to show that SE has a wider impact than just psychological manipulation by conducting physical reconnaissance alongside our social engineering.

THE CHOSEN ROLES

Both roles were responsible for their own conduct for a successful heist of the data they seeked. Objectives were set for each role to ensure smoothness.

THE ENGINEER

For this role, the person would use social engineering and pretexting to achieve the following objectives:

- Learn any information about people's projects by asking questions while maintaining the cover of construction workers.
- Establish a sense of trust, or connection.
- Buy as much time possible, so that the sniffer can collect as much data that they can.
- Analyze initial reactions and debrief groups after exercise is over.
- Demonstrate the psychological impacts of social engineering.

THE SNIFFER

For this role, the person would use network monitoring tools to achieve the following objectives:

- Identify any devices transmitting on wireless connections.
- Capture all data being transmitted in the general area.
- Debrief and report on all data collected during analysis phase.
- Demonstrate the physical/logical impacts of social engineering.



THE ENGINEER

To ensure the sniffer could carry out its duties, the impersonator buys enough time by using social engineering tactics to pry out any information and keep eyes off the sniffer.

Impersonators kept suspicion low by using authentic equipment, speaking in vague but technical terms, and using environmental context to establish a readily believable story for further psychological pivoting.

Additionally, audio was recorded both before and after the exercise reveal to debrief on results and establish a burden of proof for SE attempts and group responses.

PACKET SNIFFER

The engineer assigned to packet sniffing utilized a variety of tools to capture, store, and analyze data. As the Engineer stalled for data, the sniffer would conduct the capture.

- Wireshark and Kismet were used for packet capture.
- NetworkMiner identified patterns and communication in PCAPS.
- Monitor Mode Antenna was used to retrieve packets without direct connection.
- Authentic gear hid all notable features for harder identification of physical threat within social engineering.



RESULTS

After surveying 19 groups, we analyzed the exercise debriefs and found an average suspicion-to-belief ratio of 80:20.

Of the groups that grew suspicious, fewer took action. Those actions included:

- 1 active report to organizers on suspicious social engineering activity.
- 1 attempt at verification of employment of the engineers through their employee ID.
- 1 attempt to hamper sniffer activity by enabling airplane mode.

Only 7 groups displayed active resistance and hesitation to social engineering.

Despite these actions, many more were willing to give up information that a real social engineer would find useful, even within a competition environment.

- 17 of the 19 groups disclosed their active network connection method, allowing tailored sniffing on a specific bandwidth to occur.
- Despite suspicion, many played along, which can be dangerous, since the sniffer could still capture their data without having them directly giving up their information.
- Lack of action from groups allowed the social engineering to spread to other groups without competitors warning each other of it occurring.

FEEDBACK

WHY PEOPLE BELIEVED US

Story Plausibility

- Documented Wi-Fi drops had occurred and, our inclusion of those details in our pretext was plausible to people. The surveyors weaponized a real, ongoing convenience

Appearance

- The appearance of construction workers didn't initially raise suspicion, as they did not match the expected look of a social engineer.

Prop Justification

- Although the antenna was used for a different purpose, the sight of it related to the story that we provided to people, convincing them that we were actual construction workers.

WHY THE PRETEXT FAILED

Visual/Wardrobe Anomalies

- A lack of gear paired with new-looking equipment, as well as a dedicated cybersecurity laptop, aroused suspicion in those who took a closer look. They understood how the average construction worker should look, which did not match their view.

Logical Anomalies

- Although the pretext established itself well with context, the logical conclusion people point to is that construction workers do not deal with IT infrastructure.

Personal Recognition

- Several group members recognized some members of our team, which immediately blew their cover, and the roles were forced to rotate.

CONCLUSION

Although we had a high suspicion rate, we would still largely consider our **exercise a success** for social engineering for several reasons:

- Despite claims of suspicion, many did not conduct any action against us, having expected others to do so or not taking the threat as serious, acting as a bystander instead.
- Others, understandingly, assumed it was organized by the competition staff, and did not take the threat as serious as they would have in another context.
- Students gave mismatching info during their debrief, hinting that they may have potentially been lying about their suspicion, compared to how much information they, or their team provided.

EVIDENCE

```
898111 7502.360235   ca:0c:14:01:6e:42   Mist_d3:f7:51       802.11     64 Null function (No data), SN=323, FN=0, Flags=...P...TC
898112 7502.364349   Mist_d3:f7:51       Broadcast           802.11    359 Beacon frame, SN=3853, FN=0, Flags=........C, BI=100, SSID="AirRowdy"
898113 7502.364360   Mist_d3:f7:52       Broadcast           802.11    359 Beacon frame, SN=3854, FN=0, Flags=........C, BI=100, SSID="UTSA_PSK"
898114 7502.365226   Mist_d3:f7:53       Broadcast           802.11    367 Beacon frame, SN=3855, FN=0, Flags=........C, BI=100, SSID="eduroam"
898115 7502.365277   Mist_d3:f7:54       Broadcast           802.11    343 Beacon frame, SN=3856, FN=0, Flags=........C, BI=100, SSID="AirRowdy Guest"
898116 7502.366207   Mist_d3:f7:55       Broadcast           802.11    361 Beacon frame, SN=3857, FN=0, Flags=........C, BI=100, SSID="RowdyHacks"
898117 7502.379931   ea:10:bb:98:61:e3   Mist_d3:dc:91       802.11     64 Null function (No data), SN=888, FN=0, Flags=.......TC
898118 7502.397663   76:81:17:ab:be:ce   Broadcast           AWDL      659 Master Indication
898119 7502.429789   Mist_d3:dc:91       Broadcast           802.11    359 Beacon frame, SN=1727, FN=0, Flags=........C, BI=100, SSID="AirRowdy"
898120 7502.430214   Mist_d3:dc:92       Broadcast           802.11    359 Beacon frame, SN=1728, FN=0, Flags=........C, BI=100, SSID="UTSA_PSK"
898121 7502.430862   Mist_d3:dc:93       Broadcast           802.11    367 Beacon frame, SN=1729, FN=0, Flags=........C, BI=100, SSID="eduroam"
898122 7502.431325   Mist_d3:dc:94       Broadcast           802.11    343 Beacon frame, SN=1730, FN=0, Flags=........C, BI=100, SSID="AirRowdy Guest"
898123 7502.431848   Mist_d3:dc:95       Broadcast           802.11    362 Beacon frame, SN=1731, FN=0, Flags=........C, BI=100, SSID="RowdyHacks"
898124 7502.439847   Apple_6a:61:86      Mist_d3:dc:91       802.11     64 Null function (No data), SN=1817, FN=0, Flags=...P...TC
898125 7502.466392   Mist_d3:f7:51       Broadcast           802.11    359 Beacon frame, SN=3858, FN=0, Flags=........C, BI=100, SSID="AirRowdy"
898126 7502.466709   Mist_d3:f7:52       Broadcast           802.11    359 Beacon frame, SN=3859, FN=0, Flags=........C, BI=100, SSID="UTSA_PSK"
898127 7502.467381   Mist_d3:f7:53       Broadcast           802.11    367 Beacon frame, SN=3860, FN=0, Flags=........C, BI=100, SSID="eduroam"
898128 7502.467682   Mist_d3:f7:54       Broadcast           802.11    343 Beacon frame, SN=3861, FN=0, Flags=........C, BI=100, SSID="AirRowdy Guest"
898129 7502.468302   Mist_d3:f7:55       Broadcast           802.11    361 Beacon frame, SN=3862, FN=0, Flags=........C, BI=100, SSID="RowdyHacks"
898130 7502.470242   fa:d4:1e:19:b3:1f   Broadcast           AWDL      411 Master Indication
```

- Above is a portion of the network traffic obtained, which includes broadcasts from the local access points and devices. All actual student PII that was captured has been removed for the scope of this competition.



Provided information about what devices they were using



Did not suspect social engineering



Was suspicious and didn't give information but never informed anyone



Provided Details about their project



Turned on Airplane mode

- The following videos include the results from both the recorded answer section and the feedback section. The checkmark represent the answers that we were looking for and the x mark means that the answer they provided was dangerous for their security and was a risk. The question mark is a mixture of both.